[redacted] Case Study 4: Sandhaven University (SU)

1. University Description

Industry and Purpose
Sandhaven University (SU) is a private, nonprofit higher education institution located in California. Its primary purpose is to provide undergraduate- and graduate-level education in a variety of disciplines, including technology, business, healthcare, and liberal arts. SU also engages in academic research and community outreach.

Location
The headquarters and primary campus are based in Los Angeles, California. SU also maintains a robust international presence through several study abroad programs and exchange programs with European nations.

Size
SU has 2,500 full-time employees, including faculty and administrative staff. It operates from one main campus and two satellite campuses in California. The university enrolls approximately 25,000 students annually.

Business or Entity Interactions
Sandhaven University collaborates with both public and private organizations. As a research institution, SU has faculty members who routinely apply for and receive National Science Foundation grant funding. SU also participates in the CyberCorps Scholarship for Service program. All financial payments from student loans, scholarships, grants, and direct transactions are handled through a third-party vendor. This includes campus cafeterias, bookstores, and other retail sales involving cash and credit or debit cards. The university is satisfied with the service and believes that an internal auditing process for these activities could be eliminated.

2. Current Cybersecurity Workforce Structure

Monitoring and Response Staff
SU has a small, dedicated IT team consisting of four network and systems administrators who are also responsible for secondary duties in monitoring security alerts, handling incident response, and managing basic security functions.

Compliance Staff
Compliance with legal and industry regulations is overseen by the Legal and Compliance Office, which primarily focuses on student privacy and institutional reporting. Cybersecurity compliance responsibilities are delegated to offices responsible for individual systems.

Record Management
The Registrar's Office manages the storage and dissemination of all student records. With only three employees, the office is currently facing a 90-day backlog in responding to records requests. Approximately 20% of all records have been added to a third-party record solution that will automate the request process. Because of the volume of paper records, staff have struggled to validate requests and ensure records are being released with proper consent.

[redacted]

3. Type of Information Managed

educational records: personally identifiable information (PII) of students, including academic history, enrollment, and transcripts

financial transactions: student tuition payments, financial aid processing, and credit card transactions

healthcare information: limited personal health information (PHI) related to student health services and on-campus clinics

international student data: data on international students and faculty

protected systems: data is transmitted and stored through cloud-based platforms, third-party student information systems (SISs), and in-house databases; faculty research systems also contain sensitive or confidential research data

4. Established Policies, Procedures, and Governance

Password Policy

SU's password policy has been in place since 2012 and requires all faculty, staff, and students to change passwords annually. Passwords must consist of at least six characters, and no special complexity or history is required.

Acceptable Use Policy

The current acceptable use policy (AUP) prohibits the use of any SU system for business activity outside the university and outlines consequences for accessing adult, extremist, and foreign adversary content. The policy was updated in 2023, at the request of the vice president for business and finance, to allow the use of personal social media, email, and public artificial intelligence tools.

Security Training Policy

All SU faculty and staff are required to complete annual security training after receiving a policy briefing during onboarding. This course is used by all state employees and takes approximately two hours to complete with topics such as threats to elected officials, tax data regulations, university system requirements, and law enforcement concerns.

Disaster Recovery Plan

The SU disaster recovery plan (DRP) was framed by an external consultant in 2024. It outlines notification procedures, document management, and contact information. IT staff intend to add information regarding potential natural disasters and determine how the organization should prepare to recover from them.

Security Auditing Procedure

SU has created a standard operating procedure for security auditing in response to a state audit finding. This procedure requires all faculty, staff, and student user accounts to be audited every 24 months and validated by a network administrator. Network administrators also audit administrative groups annually to validate that all members are current SU faculty or staff.

5. Security Goals and Objectives

- Maintain business continuity through tested and validated procedures
- Ensure at least 99% uptime of all student-facing systems
- Enhance the availability of research data for faculty and staff
- Improve cybersecurity governance across the enterprise
- Develop policies, procedures, and practices to prevent or minimize the impact of security incidents
- Phase out legacy platforms and those requiring elevated privileges to function
- Identify security risks and mitigation strategies for artificial intelligence–driven tools
- Adopt unified solutions for security monitoring and patch management
- Establish a dedicated cybersecurity team to mature the information security program

POST-INCIDENT REPORT 1: Sandhaven University

INCIDENT NAME	LOCATION
MOVEit File Transfer Exploitation	Los Angeles, CA

SUMMARY

SU staff were made aware of a critical vulnerability (CVE-2023-34362) in a deployed instance of MOVEit Transfer 2020.0.X (v12.0) by a longstanding software vendor. The tool is used regularly by over 200 faculty and staff to securely transfer files. Since there was no specific plan or governance, a generic service request was created by an IT business analyst. Upon investigation, it was discovered that research data and student financial records had been actively exploited for approximately 90 days. SU staff mapped the findings to the MITRE ATT&CK framework, revealing possible foreign actor involvement. Due to the critical severity and impact, the local FBI field office was notified. After investigation, a third-party consultant was contracted to perform remediation.

ROOT CAUSE

The organization used an outdated software version without plans or documentation for updates or the identification and remediation of security vulnerabilities. External exfiltration was enabled by a lack of continuous network monitoring and limited edge firewall configurations.

LESSONS LEARNED

POST-INCIDENT REPORT 2: Sandhaven University

INCIDENT NAME	LOCATION
College of Healthcare Ransomware	Los Angeles, CA

SUMMARY

SU IT staff were alerted by telephone of a workstation in the nursing building displaying odd messages and failing to boot. Over the next four hours, 46 additional calls were confirmed for the same issue. These issues comprised 100% of the active hosts on the network segment in this facility. Upon confirming possible ransomware, a network administrator isolated the network segment and contacted a local security vendor. The next morning, a ransom message was sent to leadership and IT distribution lists. Two weeks later, the vendor confirmed the presence of TrickBot malware, Cobalt Stroke beacons, and Maze ransomware. Because this halted critical operations in the program, leaders elected to transfer $100,000 worth of Ethereum to a provided wallet. No insurance claims or law enforcement notifications were made since the funds were readily available.

ROOT CAUSE

A clinical instructor received an email that appeared to be a student submission containing a PDF document and video presentation in a zipped folder. The user extracted and opened each file, leading to initial access. While the sender resembled a student email address, the message originated from outside the SU domain and no security alerts were triggered.

LESSONS LEARNED